

Scenario

Review the following scenario. Then complete the step-by-step instructions.

You are a newly hired cybersecurity analyst for an e-commerce company. The company stores information on a remote database server, since many of the employees work remotely from locations all around the world. Employees of the company regularly query, or request, data from the server to find potential customers. The database has been open to the public since the company's launch three years ago. As a cybersecurity professional, you recognize that keeping the database server open to the public is a serious vulnerability.

You are tasked with completing a vulnerability assessment of the situation to communicate the potential risks to decision makers at the company. You must create a written report that explains how the vulnerable server is a risk to business operations and how it can be secured.

Vulnerability Assessment Report

1st January 20XX

System Description

The server hardware consists of a powerful CPU processor and 128GB of memory. It runs on the latest version of Linux operating system and hosts a MySQL database management system. It is configured with a stable network connection using IPv4 addresses and interacts with other servers on the network. Security measures include SSL/TLS encrypted connections.

Scope

The scope of this vulnerability assessment relates to the current access controls of the system. The assessment will cover a period of three months, from June 20XX to August 20XX. [NIST SP 800-30 Rev. 1](#) is used to guide the risk analysis of the information system.

Purpose

Consider the following questions to help you write:

- *How is the database server valuable to the business?*
- *Why is it important for the business to secure the data on the server?*
- *How might the server impact the business if it were disabled?*
-

The company's database server is crucial for its operations. Employees use it to regularly request data and find potential customers. The data stored on the server contains customer's information (PII) and must remain confidential and protected following laws and regulations. Allowing customer's data to remain unprotected might cause data leaks, financial and legal consequences.

If the company's database were to be disabled , the company might risk having all its operations halted due to not being able to access the database.

This vulnerability assessment will allow us to identify different threat sources (human, technological, environmental) and threat events that could potentially cause damage to the business operations .

Risk Assessment

Threat source	Threat event	Likelihood	Severity	Risk
<i>Employee</i>	Perform reconnaissance and surveillance of organization	1	2	2
<i>Customer/ Employee</i>	Alter/Delete critical information	2	3	6
<i>Competitor/ Hacker</i>	Obtain sensitive information via exfiltration	3	3	9
<i>Employee</i>	Abusing of its privilege for personal profit	3	3	9

Approach

Risks considered the data storage and management methods of the business. The likelihood of a threat occurrence and the impact of these potential events were weighed against the risks to day-to-day operational needs.

For the company's database, the most likely threat source would be human. Since its database is in a remote server, environmental factors as well as technological factors are less likely to be the most impactful sources of issues.

The database being open to public use is the most important factor which means that it is open to anyone to read, write and access. This exposure may invite threat actors to use the company's database for unintended uses such as : reading confidential information, modifying personal data and breaking the server down (deleting and compromising information). The possibilities are endless since there is no authentication nor authorization methods in place.

Remediation Strategy

Implementation of authentication, authorization, and auditing mechanisms to ensure that only authorized users access the database server. This includes using strong passwords, role-based access controls, and multi-factor authentication to limit user privileges. Encryption of data in motion using TLS instead of SSL. IP allow-listing to corporate offices to prevent random users from the internet from connecting to the database.

First, we have to restrain the access to the company's database for only those authorized (company's employees and other users that need the access).

The implementation of authentication (username/id and strong password) will be the first layer of verification.

Next, once the user account has been created for every employee or user, we have to implement MFA (multiple-factor authentication) in case its credentials are stolen or leaked.

Once the user or employee login, we have to restrict its privilege to be sure that only allowed and intended actions can be taken by the employee or user to avoid privilege abuse (least privilege rule).

A clear distinction of every employee or user in the company's database will allow more control and protection over its data as well as allowing the company to keep track of the flow of information using the logs journal .